

LAB 3

PARAMETER TAMPERING

BÁO CÁO THỰC HÀNH AN TOÀN ỨNG DỤNG WEB

MSSV: 21127645

Họ tên: Lê Minh

Mục lục

- Chương 1. Giới thiệu
- Chương 2. Cơ sở lý thuyết
- Chương 3. Parameter Tampering
- Chương 4. Kiến trúc Lab03
- Chương 5. Dữ liệu và tài khoản mẫu
- Chương 6. Thay đổi giá sản phẩm
- Chương 7. Vá lỗi thay đổi giá
- Chương 8. IDOR hóa đơn
- Chương 9. Vá IDOR
- Chương 10. Thay đổi role
- Chương 11. Vá role tampering
- Chương 12. Request Inspector và Parameter Diff
- Chương 13. Authorization Model
- Chương 14. Audit Logging
- Chương 15. So sánh Parameter Tampering và SQL Injection
- Chương 16. Phòng chống
- Chương 17. Trả lời câu hỏi báo cáo
- Chương 18. Kiểm thử
- Chương 19. Kết luận

Chương 1. Giới thiệu

Parameter Tampering là việc sửa dữ liệu do client gửi để làm sai lệch quyết định của server. Lab03 minh họa toàn bộ đường đi từ browser, HTTP request, Flask, xác thực, phân quyền, SQLite, audit log đến response.

Mục tiêu là chứng minh ba lỗi logic: sửa giá sản phẩm, IDOR hóa đơn và mass assignment role. Mỗi lỗi có bản vulnerable để quan sát nguyên nhân và bản secure để kiểm chứng bản vá.

Phạm vi an toàn chỉ gồm 127.0.0.1, máy ảo local hoặc Docker local. Dữ liệu đều giả lập; không có thanh toán, email, tài khoản thật, host tùy ý, proxy tổng quát hay request Internet.

Giới hạn: bản vulnerable chỉ phục vụ giáo dục, không phải mẫu triển khai. Ảnh được chụp thủ công; trace và audit phải sinh từ request thật của lab.

Chương 2. Cơ sở lý thuyết

HTTP request có thể mang tham số trong query string, form body, header và cookie. Hidden field và localStorage vẫn nằm dưới quyền kiểm soát của trình duyệt nên không tạo ranh giới tin cậy.

Session xác định người dùng sau đăng nhập. Authentication trả lời ai đang yêu cầu; authorization trả lời người đó được làm gì với đối tượng cụ thể. Object-level authorization phải kiểm tra quyền trên từng invoice.

IDOR xảy ra khi server dùng mã đối tượng do client gửi nhưng không kiểm tra quyền sở hữu. Mass assignment xảy ra khi server gán trực tiếp nhiều field từ request, kể cả field nhạy cảm như role.

Server-side validation kiểm tra kiểu, phạm vi và trạng thái; business logic phải lấy dữ liệu có thẩm quyền như giá từ database. Audit logging ghi dấu hiệu tampering nhưng không được ghi password, secret hay toàn bộ cookie.

Chương 3. Parameter Tampering

Lỗi hỏng xuất hiện khi ứng dụng coi dữ liệu client là dữ liệu đáng tin và dùng nó để tính tiền, chọn chủ thể hoặc thay đổi quyền. Các bề mặt thường gặp gồm URL, form, hidden field, cookie, localStorage và header tùy chỉnh.

Client-controlled data gồm product_id, quantity, submitted price, invoice id, email và field thừa. Trusted server data gồm user_id từ session, giá từ products, role từ database và quan hệ owner của invoice.

Ảnh hưởng có thể là sai lệch tài chính, rò rỉ dữ liệu, thay đổi tài khoản khác hoặc nâng quyền. Validate kiểu dữ liệu chưa đủ vì một integer hợp lệ vẫn có thể trỏ đến invoice không thuộc quyền.

Chương 4. Kiến trúc Lab03

Browser render Jinja, gửi request đến Flask tại 127.0.0.1:5003. Flask đọc session, validate input, gọi business logic và authorization trước khi truy vấn SQLite bằng parameterized query.

Trace service lưu các bước Browser UI -> HTTP Request -> Flask Router -> Authentication -> Input Validation -> Business Logic -> Authorization -> SQLite Query/Write -> Audit Logging -> HTTP Response -> Final Result.

Sequence tổng quát: User -> Browser -> Flask route -> Session identity -> Validation -> Business logic -> Authorization -> SQLite transaction -> Audit/Trace -> Response.

Security headers là defense in depth cho browser; chúng không thay thế kiểm tra giá, ownership hoặc field allowlist.

Chương 5. Dữ liệu và tài khoản mẫu

User A có id 12 và sở hữu invoice 1001, 1003. User B có id 13 và sở hữu invoice 1002. Admin có id 1 và được phép xem invoice theo chính sách owner-or-admin.

Giá có thẩm quyền nằm ở bảng products: USB Security Key 100000 VND, Wireless Mouse 250000 VND, Mechanical Keyboard 1200000 VND, Lab Laptop 15000000 VND.

Password được hash bằng Werkzeug. Session chỉ lưu user_id, username, role và lab_mode; giao diện chỉ hiển thị cookie đã che.

Bảng 1. Tài khoản mẫu

ID	Username	Email	Role
12	user_a	usera@lab.local	user
13	user_b	userb@lab.local	user
1	admin	admin@lab.local	admin

Bảng 2. Sản phẩm mẫu

ID	Tên	Giá VND	Stock
5	USB Security Key	100000	20
6	Wireless Mouse	250000	15
7	Mechanical Keyboard	1200000	10
8	Lab Laptop	15000000	5

Chương 6. Thay đổi giá sản phẩm

Luồng hợp lệ gửi product_id=5, quantity=1, price=100000. Trong bản vulnerable, request.form['price'] được chuyển thành số và dùng trực tiếp để tính total rồi ghi invoice.

Khi client sửa price=1, server vẫn tạo invoice có unit_price=1 và total=1. Nguyên nhân là tin hidden field và không truy vấn lại products.price_vnd.

Tác động là tổn thất tài chính giả lập và dữ liệu invoice sai. Database Inspector chứng minh giá client, giá database và giá đã lưu khác nhau.

Chương 7. Vá lỗi thay đổi giá

Route secure chỉ dùng product_id và quantity sau validation. Server truy vấn sản phẩm, kiểm tra quantity từ 1 đến 10, kiểm tra stock và tính total bằng price_vnd trong database.

Nếu request vẫn chứa price=1, server đánh dấu là untrusted, bỏ qua giá client, ghi checkout_price_mismatch và tạo invoice 100000 VND trong transaction.

Bản vá hiệu quả vì nguồn giá có thẩm quyền được quyết định phía server. Audit mismatch hỗ trợ phát hiện nhưng không phải cơ chế đảm bảo giá.

Chương 8. IDOR hóa đơn

User A mở invoice 1001 rồi đổi query id thành 1002. Route vulnerable truy vấn WHERE id = ? mà không ràng buộc owner nên trả invoice giả lập của User B.

invoice_id=1002 là số nguyên hợp lệ, cho thấy input validation không đồng nghĩa authorization. Lỗi thuộc nhóm Broken Access Control trong OWASP Top 10.

Tác động là rò rỉ dữ liệu đối tượng. UI chỉ hiển thị dữ liệu lab cần thiết, nhưng verdict vẫn ghi rõ tài nguyên trái phép đã lộ.

Chương 9. Vá IDOR

Route secure lấy current_user_id từ session. Với user thường, truy vấn invoice theo cả id và user_id; admin được phép theo chính sách công khai owner-or-admin.

Nếu invoice tồn tại nhưng không thuộc user, server trả HTTP 403 trước khi render nội dung và ghi `invoice_access_denied`. Response không chứa dòng hàng hay tổng tiền invoice 1002.

Không dùng ID khó đoán làm bảo mật. Chính sách phải được áp dụng trên từng object và từng request.

Chương 10. Thay đổi role

Form vulnerable render hidden `user_id=12` và `role=user`. Client sửa `role=admin`; route đọc các field và cập nhật trực tiếp, minh họa mass assignment.

Database đổi role từ user thành admin và session được đồng bộ để chứng minh privilege escalation. Client còn có thể sửa `user_id` để nhắm tài khoản khác trong bản lỗi.

Đây là lỗi phân quyền, không phải SQL Injection: query vẫn parameterized nhưng dữ liệu hợp lệ được dùng sai mục đích.

Chương 11. Vá role tampering

Form secure chỉ gửi email. Server lấy `user_id` từ session, validate email và dùng allowlist duy nhất `{'email'}`; role, `user_id`, `is_admin` và field lạ bị từ chối hoặc bỏ qua.

Khi `role=admin` được thêm thủ công, server ghi `sensitive_field_submitted`, giữ role trong database và không đồng bộ session từ client.

Chức năng quản trị role, nếu có, phải là route riêng với authorization admin và re-authentication phù hợp; nó không thuộc self-service profile.

Chương 12. Request Inspector và Parameter Diff

Inspector hiển thị method, path, query, content type, form body, timestamp và handler. Password, secret key và cookie đầy đủ luôn bị loại bỏ.

Mỗi parameter được phân loại trusted server value, untrusted client value, sensitive, modified, ignored, validated hoặc authorized. Diff đặt original cạnh submitted và nguồn tin cậy tương ứng.

Request Tampering Console chỉ có scenario và route allowlist trong Lab03; người dùng không thể nhập host hoặc URL tùy ý.

Chương 13. Authorization Model

Mô hình quyết định gồm Subject, Action, Object, Owner, Required permission, Policy, Decision và Reason.

IDOR secure: subject user 12, action read invoice, object invoice 1002, owner user 13, policy owner-or-admin, decision deny.

Profile secure: subject user 12, action update role, object user 12, required permission admin, decision deny vì role không thuộc allowlist self-service.

Chương 14. Audit Logging

Các event chính gồm `checkout_price_mismatch`, `invoice_access_denied`, `sensitive_field_submitted`, `target_user_mismatch`, `invalid_quantity`, `invalid_product_id`, `unknown_parameter` và `authorization_denied`.

Log lưu timestamp, user, route, mode, parameter, original/submitted value, decision, reason và `trace_id`. Không lưu password, secret hoặc cookie đầy đủ.

Audit hỗ trợ phát hiện cùng một user liên tục sửa giá, quét ID hoặc gửi field nhạy cảm. Log cần giám sát và chính sách cảnh báo; bản thân log không chặn tấn công.

Chương 15. So sánh Parameter Tampering và SQL Injection

Parameter Tampering sửa giá trị hợp lệ để làm sai business logic hoặc access control. SQL Injection chèn cú pháp để thay đổi cấu trúc câu SQL.

Parameterized SQL ngăn dữ liệu bị diễn giải như mã SQL. Nó không tự ngăn server tin `price=1`, thiếu ownership check hoặc chấp nhận `role=admin`.

Bản vá Parameter Tampering cần nguồn dữ liệu server, session identity, object-level authorization, field allowlist và validation theo ngữ cảnh.

Tiêu chí	Parameter Tampering	SQL Injection
Mục tiêu	Sai logic/quyền	Đổi câu SQL
Kỹ thuật	Sửa giá trị	Chèn cú pháp
Bản vá	Nguồn server + authorization	Parameterized query

Chương 16. Phòng chống

Không tin dữ liệu client; lấy giá từ database; lấy danh tính từ session; authorization trên từng object; allowlist field; không gửi field nhạy cảm; validate kiểu, phạm vi và stock.

Dùng database transaction, parameterized SQL, audit logging, request size limit, least privilege, kiểm thử hồi quy và re-authentication cho thao tác nhạy cảm.

Rate limiting có thể giảm dò ID hoặc spam log nhưng không thay bản vá logic. CSP, SameSite và CSRF là lớp khác; CSRF token không vá IDOR.

Chương 17. Trả lời câu hỏi báo cáo

1. Parameter Tampering đổi giá trị request để lừa logic; SQL Injection đưa cú pháp vào input để đổi câu truy vấn. Hai lỗi có nguyên nhân và bản vá khác nhau.
2. Hidden field không phải cơ chế bảo mật vì người dùng kiểm soát DOM và request, có thể sửa bằng DevTools hoặc công cụ gửi request.
3. IDOR thuộc Broken Access Control trong OWASP Top 10; cụ thể là thiếu object-level authorization.
4. Trước khi trả invoice, server phải xác thực session, validate id, tìm object, kiểm tra owner hoặc quyền admin, rồi mới render dữ liệu.
5. Không truyền giá như nguồn quyết định vì client sửa được. Server phải lấy giá hiện hành từ database và tính tổng.
6. `user_id` trong form không xác định danh tính vì do client kiểm soát; session đã xác thực mới là nguồn danh tính.
7. role không nên xuất hiện trong self-service form vì không cần cho cập nhật email và tạo bề mặt mass assignment.
8. Validate kiểu chưa đủ: `invoice_id=1002` và `role='admin'` đều đúng kiểu nhưng có thể trái quyền.
9. Quyền phải kiểm tra trên từng object vì quyền xem invoice 1001 không suy ra quyền xem invoice 1002.
10. Audit log ghi parameter, giá trị gốc/gửi, quyết định và trace, giúp phát hiện mẫu hành vi bất thường mà không lộ secret.
11. Session được Flask ký và dùng làm ngữ cảnh đã xác thực; hidden field là dữ liệu browser có thể sửa. Dù session có role, server vẫn nên đối chiếu database cho thao tác nhạy cảm.

Chương 18. Kiểm thử

Pytest bao phủ login, hash password, route cần session, cart, vulnerable/secure checkout, IDOR, role, authorization, validation, audit, trace, security headers, report, screenshot guide và local-only scripts.

Demo flows tạo request, response, trace JSON, audit và database snapshot thật. Kết quả pytest được lưu vào evidence/logs/pytest.txt; báo cáo chỉ đọc log đó, không ghi cứng kết quả.

Chương 19. Kết luận

Lab chứng minh client không phải vùng tin cậy. Ba bản vulnerable cho thấy cùng một nguyên nhân gốc biểu hiện thành sai giá, rò rỉ object và nâng quyền.

Bản secure đưa quyết định về server: giá database, session identity, object authorization và allowlist. Audit/trace làm quyết định có thể quan sát và kiểm chứng.

Giới hạn là dữ liệu cố định, SQLite single-process và không có hệ thống cảnh báo tập trung. Hướng phát triển an toàn là policy tập trung, re-authentication, rate limiting và giám sát audit trong môi trường triển khai thật.

Phụ lục A. Ảnh chụp từng bước

Hình 1. 01_home_overview.png

ẢNH CẦN BỔ SUNG: 01_home_overview.png
Tài khoản: Chưa bắt buộc
URL: /
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: Ba bài thực hành checkout, IDOR và role tampering.

Hình 1: Tổng quan Lab03. Ba bài thực hành checkout, IDOR và role tampering.

Hình 2. 02_login_user_a.png

ẢNH CẦN BỔ SUNG: 02_login_user_a.png
Tài khoản: Chưa đăng nhập
URL: /login
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: Thông tin user_a và cảnh báo chỉ dùng dữ liệu lab.

Hình 2: Tài khoản mẫu User A. Thông tin user_a và cảnh báo chỉ dùng dữ liệu lab.

Hình 3. 03_products_database_price.png

ẢNH CẦN BỔ SUNG: 03_products_database_price.png
Tài khoản: user_a
URL: /products
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: Sản phẩm 5 có giá 100000 VND.

Hình 3: Giá tin cậy từ database. Sản phẩm 5 có giá 100000 VND.

Hình 4. 04_cart_before_checkout.png

ẢNH CẦN BỔ SUNG: 04_cart_before_checkout.png
Tài khoản: user_a
URL: /cart
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: User A có sản phẩm 5, số lượng 1.

Hình 4: Giỏ hàng trước checkout. User A có sản phẩm 5, số lượng 1.

Hình 5. 05_checkout_original_parameters.png

ẢNH CẦN BỔ SUNG: 05_checkout_original_parameters.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: Không sửa
Panel: Parameter Inspector
Phải xuất hiện: product_id=5, quantity=1, price=100000.

Hình 5: Tham số checkout gốc. product_id=5, quantity=1, price=100000.

Hình 6. 06_checkout_hidden_price_devtools.png

ẢNH CẦN BỔ SUNG: 06_checkout_hidden_price_devtools.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: Không sửa
Panel: DevTools Elements
Phải xuất hiện: DevTools Elements hiển thị hidden price=100000.

Hình 6: Hidden field vẫn do client kiểm soát. DevTools Elements hiển thị hidden price=100000.

Hình 7. 07_checkout_price_modified.png

ẢNH CẦN BỔ SUNG: 07_checkout_price_modified.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Parameter Diff
Phải xuất hiện: Parameter Diff đánh dấu price modified.

Hình 7: So sánh giá trước và sau sửa. Parameter Diff đánh dấu price modified.

Hình 8. 08_checkout_tampered_request.png

ẢNH CẦN BỔ SUNG: 08_checkout_tampered_request.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Request Inspector
Phải xuất hiện: Request Inspector hiển thị price=1.

Hình 8: Request checkout đã bị sửa. Request Inspector hiển thị price=1.

Hình 9. 09_checkout_vulnerable_server_logic.png

ẢNH CẦN BỔ SUNG: 09_checkout_vulnerable_server_logic.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Timeline
Phải xuất hiện: Bước Business Logic dùng request.form['price'].

Hình 9: Server lỗi tin submitted price. Bước Business Logic dùng request.form['price'].

Hình 10. 10_checkout_wrong_invoice.png

ẢNH CẦN BỔ SUNG: 10_checkout_wrong_invoice.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Final Result
Phải xuất hiện: Invoice mới có total 1 VND.

Hình 10: Invoice sai giá. Invoice mới có total 1 VND.

Hình 11. 11_checkout_vulnerable_database.png

ẢNH CẦN BỔ SUNG: 11_checkout_vulnerable_database.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Database Inspector
Phải xuất hiện: unit_price=1 và total=1.

Hình 11: Database lưu giá sai. unit_price=1 và total=1.

Hình 12. 12_checkout_vulnerable_verdict.png

ẢNH CẦN BỔ SUNG: 12_checkout_vulnerable_verdict.png
Tài khoản: user_a
URL: /vulnerable/checkout
Dữ liệu cần sửa: price=1
Panel: Final Security Verdict
Phải xuất hiện: Parameter Tampering thành công.

Hình 12: Kết luận checkout vulnerable. Parameter Tampering thành công.

Hình 13. 13_checkout_secure_request.png

ẢNH CẦN BỔ SUNG: 13_checkout_secure_request.png
Tài khoản: user_a
URL: /secure/checkout
Dữ liệu cần sửa: price=1
Panel: Request Inspector
Phải xuất hiện: Request vẫn có price=1 nhưng được đánh dấu untrusted.

Hình 13: Cùng request gửi vào route secure. Request vẫn có price=1 nhưng được đánh dấu untrusted.

Hình 14. 14_checkout_secure_database_lookup.png

ẢNH CẦN BỔ SUNG: 14_checkout_secure_database_lookup.png
Tài khoản: user_a
URL: /secure/checkout
Dữ liệu cần sửa: price=1
Panel: Timeline
Phải xuất hiện: SQLite Query lấy products.price_vnd=100000.

Hình 14: Secure lookup giá server. SQLite Query lấy products.price_vnd=100000.

Hình 15. 15_checkout_price_mismatch.png

ẢNH CẦN BỔ SUNG: 15_checkout_price_mismatch.png
Tài khoản: user_a
URL: /secure/checkout
Dữ liệu cần sửa: price=1
Panel: Parameter Diff
Phải xuất hiện: submitted_price=1 khác database_price=100000.

Hình 15: Phát hiện price mismatch. submitted_price=1 khác database_price=100000.

Hình 16. 16_checkout_secure_invoice.png

ẢNH CẦN BỔ SUNG: 16_checkout_secure_invoice.png
Tài khoản: user_a
URL: /secure/checkout
Dữ liệu cần sửa: price=1
Panel: Database Inspector
Phải xuất hiện: Invoice có total 100000 VND.

Hình 16: Invoice secure đúng giá. Invoice có total 100000 VND.

Hình 17. 17_checkout_audit_log.png

ẢNH CẦN BỔ SUNG: 17_checkout_audit_log.png
Tài khoản: user_a
URL: /audit-logs
Dữ liệu cần sửa: price=1
Panel: Audit Inspector
Phải xuất hiện: Event checkout_price_mismatch cùng trace ID.

Hình 17: Audit checkout tampering. Event checkout_price_mismatch cùng trace ID.

Hình 18. 18_invoice_user_a_1001.png

ẢNH CẦN BỔ SUNG: 18_invoice_user_a_1001.png
Tài khoản: user_a
URL: /vulnerable/invoice?id=1001
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: Invoice 1001 thuộc user_id 12.

Hình 18: Owner xem invoice của mình. Invoice 1001 thuộc user_id 12.

Hình 19. 19_invoice_id_changed.png

ẢNH CẦN BỔ SUNG: 19_invoice_id_changed.png
Tài khoản: user_a
URL: /vulnerable/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: Parameter Diff
Phải xuất hiện: Parameter Diff đánh dấu object reference changed.

Hình 19: Invoice ID bị đổi. Parameter Diff đánh dấu object reference changed.

Hình 20. 20_invoice_idor_request.png

ẢNH CẦN BỔ SUNG: 20_invoice_idor_request.png
Tài khoản: user_a
URL: /vulnerable/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: Request Inspector
Phải xuất hiện: GET query id=1002.

Hình 20: Request IDOR. GET query id=1002.

Hình 21. 21_invoice_idor_database.png

ẢNH CẦN BỔ SUNG: 21_invoice_idor_database.png
Tài khoản: user_a
URL: /vulnerable/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: Database Inspector
Phải xuất hiện: owner_id=13 và session user_id=12.

Hình 21: Owner không khớp session. owner_id=13 và session user_id=12.

Hình 22. 22_invoice_idor_success.png

ẢNH CẦN BỔ SUNG: 22_invoice_idor_success.png
Tài khoản: user_a
URL: /vulnerable/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: Final Security Verdict
Phải xuất hiện: User A thấy invoice giả lập của User B.

Hình 22: IDOR vulnerable thành công. User A thấy invoice giả lập của User B.

Hình 23. 23_invoice_secure_authorization.png

ẢNH CẦN BỔ SUNG: 23_invoice_secure_authorization.png
Tài khoản: user_a
URL: /secure/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: Authorization Inspector
Phải xuất hiện: Policy owner or admin đưa ra decision deny.

Hình 23: Object-level authorization. Policy owner or admin đưa ra decision deny.

Hình 24. 24_invoice_secure_403.png

ẢNH CẦN BỔ SUNG: 24_invoice_secure_403.png
Tài khoản: user_a
URL: /secure/invoice?id=1002
Dữ liệu cần sửa: id=1002
Panel: HTTP Response
Phải xuất hiện: HTTP 403 và không có dòng hàng invoice 1002.

Hình 24: Secure IDOR bị chặn. HTTP 403 và không có dòng hàng invoice 1002.

Hình 25. 25_invoice_access_denied_log.png

ẢNH CẦN BỔ SUNG: 25_invoice_access_denied_log.png
Tài khoản: user_a
URL: /audit-logs
Dữ liệu cần sửa: id=1002
Panel: Audit Inspector
Phải xuất hiện: Event invoice_access_denied cùng trace ID.

Hình 25: Audit IDOR denied. Event invoice_access_denied cùng trace ID.

Hình 26. 26_profile_original_fields.png

ẢNH CẦN BỔ SUNG: 26_profile_original_fields.png
Tài khoản: user_a
URL: /vulnerable/profile
Dữ liệu cần sửa: Không sửa
Panel: Parameter Inspector
Phải xuất hiện: Form có user_id=12, email và role=user.

Hình 26: Các trường profile vulnerable. Form có user_id=12, email và role=user.

Hình 27. 27_profile_role_modified.png

ẢNH CẦN BỔ SUNG: 27_profile_role_modified.png
Tài khoản: user_a
URL: /vulnerable/profile
Dữ liệu cần sửa: role=admin
Panel: Parameter Diff
Phải xuất hiện: Parameter Diff đánh dấu role là sensitive field modified.

Hình 27: Role bị sửa phía client. Parameter Diff đánh dấu role là sensitive field modified.

Hình 28. 28_profile_tampered_request.png

ẢNH CẦN BỔ SUNG: 28_profile_tampered_request.png
Tài khoản: user_a
URL: /vulnerable/profile
Dữ liệu cần sửa: role=admin
Panel: Request Inspector
Phải xuất hiện: POST chứa role=admin.

Hình 28: Request profile bị sửa. POST chứa role=admin.

Hình 29. 29_profile_vulnerable_update.png

ẢNH CẦN BỔ SUNG: 29_profile_vulnerable_update.png
Tài khoản: user_a
URL: /vulnerable/profile
Dữ liệu cần sửa: role=admin
Panel: Database Inspector
Phải xuất hiện: Role trước user, role sau admin.

Hình 29: Mass assignment đổi database. Role trước user, role sau admin.

Hình 30. 30_profile_privilege_escalation.png

ẢNH CẦN BỔ SUNG: 30_profile_privilege_escalation.png
Tài khoản: user_a
URL: /vulnerable/profile
Dữ liệu cần sửa: role=admin
Panel: Final Security Verdict
Phải xuất hiện: UI và session hiển thị role admin.

Hình 30: Nâng quyền vulnerable. UI và session hiển thị role admin.

Hình 31. 31_profile_secure_field_allowlist.png

ẢNH CẦN BỔ SUNG: 31_profile_secure_field_allowlist.png
Tài khoản: user_a
URL: /secure/profile
Dữ liệu cần sửa: role=admin
Panel: Authorization Inspector
Phải xuất hiện: accepted_fields=email; rejected_fields có role.

Hình 31: Secure field allowlist. accepted_fields=email; rejected_fields có role.

Hình 32. 32_profile_secure_role_unchanged.png

ẢNH CẦN BỔ SUNG: 32_profile_secure_role_unchanged.png
Tài khoản: user_a
URL: /secure/profile
Dữ liệu cần sửa: role=admin
Panel: Database Inspector
Phải xuất hiện: Database giữ role=user.

Hình 32: Role secure không đổi. Database giữ role=user.

Hình 33. 33_code_comparison_checkout.png

ẢNH CẦN BỔ SUNG: 33_code_comparison_checkout.png
Tài khoản: user_a
URL: /comparison
Dữ liệu cần sửa: Không sửa
Panel: Code Comparison
Phải xuất hiện: Code chạy thật cho client price và database price.

Hình 33: So sánh code checkout. Code chạy thật cho client price và database price.

Hình 34. 34_code_comparison_idor.png

ẢNH CẦN BỔ SUNG: 34_code_comparison_idor.png
Tài khoản: user_a
URL: /comparison
Dữ liệu cần sửa: Không sửa
Panel: Code Comparison
Phải xuất hiện: Query theo id so với query theo id và owner.

Hình 34: So sánh code IDOR. Query theo id so với query theo id và owner.

Hình 35. 35_code_comparison_role.png

ẢNH CẦN BỔ SUNG: 35_code_comparison_role.png
Tài khoản: user_a
URL: /comparison
Dữ liệu cần sửa: Không sửa
Panel: Code Comparison
Phải xuất hiện: Submitted role so với allowlist email.

Hình 35: So sánh mass assignment. Submitted role so với allowlist email.

Hình 36. 36_parameter_tampering_vs_sql.png

ẢNH CẦN BỔ SUNG: 36_parameter_tampering_vs_sql.png
Tài khoản: user_a
URL: /comparison
Dữ liệu cần sửa: Không sửa
Panel: Comparison Table
Phải xuất hiện: Bảng nêu khác mục tiêu, kỹ thuật và bản vá.

Hình 36: Phân biệt với SQL Injection. Bảng nêu khác mục tiêu, kỹ thuật và bản vá.

Hình 37. 37_security_controls.png

ẢNH CẦN BỔ SUNG: 37_security_controls.png
Tài khoản: user_a
URL: /security-controls
Dữ liệu cần sửa: Không sửa
Panel: Security Control Panel
Phải xuất hiện: Server price, session identity, authorization, allowlist và audit.

Hình 37: Các lớp kiểm soát. Server price, session identity, authorization, allowlist và audit.

Hình 38. 38_audit_logs_overview.png

ẢNH CẦN BỔ SUNG: 38_audit_logs_overview.png
Tài khoản: user_a
URL: /audit-logs
Dữ liệu cần sửa: Không sửa
Panel: Audit Inspector
Phải xuất hiện: Có checkout mismatch, IDOR denied và sensitive field submitted.

Hình 38: Audit ba tình huống. Có checkout mismatch, IDOR denied và sensitive field submitted.

Hình 39. 39_presentation_mode.png

ẢNH CẦN BỔ SUNG: 39_presentation_mode.png
Tài khoản: user_a
URL: /secure/invoice?id=1002
Dữ liệu cần sửa: Không sửa
Panel: Presentation Mode
Phải xuất hiện: Một bước Authorization ở cỡ chữ lớn và có thanh tiến trình.

Hình 39: Trình chiếu trace. Một bước Authorization ở cỡ chữ lớn và có thanh tiến trình.

Hình 40. 40_pytest_passed.png

ẢNH CẦN BỔ SUNG: 40_pytest_passed.png
Tài khoản: Không áp dụng
URL: Terminal local
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: Dòng tổng kết pytest đạt.

Hình 40: Kết quả kiểm thử. Dòng tổng kết pytest đạt.

Hình 41. 41_report_files.png

ẢNH CẦN BỔ SUNG: 41_report_files.png
Tài khoản: Không áp dụng
URL: Thư mục report
Dữ liệu cần sửa: Không sửa
Panel: Không bắt buộc
Phải xuất hiện: DOCX và PDF đúng tên.

Hình 41: Artifact báo cáo. DOCX và PDF đúng tên.

Phụ lục B. Lệnh và bằng chứng

python seed.py

python scripts/run_demo_flows.py

python scripts/check_screenshots.py

python scripts/generate_report.py

pytest

Kết quả pytest thực tế

..... [68%]

..... [100%]

105 passed in 14.36s